

Module 04: VPN Mechanics, OPSEC Realities & Provider Analysis

A Virtual Private Network (VPN) is one of the most misunderstood privacy tools in cybersecurity. Commercial marketing has convinced millions of users that clicking "Connect" makes them an untouchable ghost on the internet. In this module, we break down how VPNs actually work, where they fail, and conduct a threat-model breakdown of providers like ProtonVPN vs. Mullvad.

■ 1. How a VPN Operates Under the Hood

1.1 The Virtual Adapter & Routing Table

When a VPN client starts on your machine:

1. It creates a **virtual network interface (TUN/TAP adapter)**.
2. It modifies your operating system's **kernel routing table**, setting the default route (`0.0.0.0/0`) to point through the virtual adapter instead of your physical LAN gateway.
3. It establishes an encrypted tunnel (using protocols like **WireGuard** or **OpenVPN**) over UDP/TCP to a remote VPN server.

STANDARD CONNECTION (NO VPN)

Your App

→ Plaintext Headers →

ISP Router (Logs Everything)

→ Public IP Visible →

Target Website

VPN PROTECTED TUNNEL

Your App

→ Encrypted TUN Adapter →

ISP (Sees only UDP Stream)

→ Decrypted at VPN Node →

Target Website (Sees VPN IP)

1.2 The Trust Shift Rule

A VPN does NOT encrypt your data across the entire internet.

- The tunnel exists **only between your device and the VPN server**.
- From the VPN server to the target website, the traffic exits in whatever protocol you are using (HTTPS encrypts the payload, but the target server sees the VPN server's IP).
- **Core Rule:** A VPN does not eliminate trust; **it shifts trust from your ISP to the VPN provider.**

■ 2. Common VPN Leak Vectors & Failure Modes

Even with an active VPN, your real identity can leak through several structural flaws:

LEAK VECTOR	MECHANISM	THREAT OUTCOME
DNS Leak	OS sends DNS requests to local ISP resolver outside the VPN tunnel.	ISP still sees all domains visited.
IPv6 Leak	VPN only tunnels IPv4; outbound IPv6 requests bypass tunnel directly to ISP.	Exposes real ISP-assigned global IPv6 address.
WebRTC STUN Leak	Browser executes STUN request punching through NAT.	Remote website reads your real public and private IPs.
Kill Switch Failure	VPN connection drops momentarily; OS fails back to physical network before renegotiating.	Unencrypted packets leak real IP during reconnect.
Traffic Timing Correlation	An adversary monitoring your ISP line and the target server correlates packet burst sizes and timestamps.	Confirms you are the sender despite encryption.

3. Threat Modeling Providers: Commercial Traps vs. True OPSEC

Not all VPN providers are architected equally. When choosing an infrastructure provider, look past marketing slogans and examine the legal jurisdiction, account creation mechanics, and data retention architecture.

COMMERCIAL / PROTON

OPSEC PRIVACY SCORE

35% RATED ANONYMITY

ACCOUNT IDENTIFIER

✗ Email / Username / Password required

KYC / IDENTITY TRAIL

✗ Tied to payment records & recovery inboxes

ANONYMOUS PAYMENT

△ Limited (Requires 3rd-party KYC gateways)

LOGGING ARCHITECTURE

✗ Subject to Swiss criminal court logging orders

REAL-WORLD AUDIT

✗ Documented IP logging compliance cases

MULLVAD VPN

OPSEC PRIVACY SCORE

98% RATED ANONYMITY

ACCOUNT IDENTIFIER

✓ Random 16-Digit Token (Zero KYC)

KYC / IDENTITY TRAIL

✓ ZERO personal data collected or stored

ANONYMOUS PAYMENT

✓ Physical Cash in Mail / Monero (XMR)

LOGGING ARCHITECTURE

✓ Diskless RAM-only infrastructure

REAL-WORLD AUDIT

✓ Swedish Police raid yielded 0 logs

3.1 The Reality of Commercial VPNs & Proton

- **Account Linkage:** Providers like Proton, Nord, and Surfshark require an email address, username, and password upon registration. This immediately links your payment records, recovery accounts, and communication logs to a central identity.
- **Jurisdiction & Legal Compliance:**
 - While Switzerland (where Proton is based) has strict privacy laws, Swiss courts **can and do compel Swiss companies to log specific targets** under Swiss criminal code orders (as seen in the documented 2021 French activist case where Proton was legally forced to log IP and browser fingerprints of a target).

- No commercial provider operating a business entity is above the court orders of its sovereign jurisdiction.
- **Heavy Marketing & Affiliate Schemes:** Most "top 10 VPN" review sites are owned by the VPN companies themselves or run on massive recurring affiliate payouts, skewing technical recommendations.

3.2 Why Mullvad Sets the Benchmark for Privacy

Mullvad is widely regarded by systems engineers and security researchers as the gold standard for network proxying due to its strict zero-knowledge architecture:

1. No Account Information:

- Mullvad generates a **random 16-digit account number**.
- It never asks for an email, phone number, name, or password.

2. Anonymous Payment Methods:

- Accepts **cash mailed in a physical envelope** with only the account token written inside.
- Accepts **Monero (XMR)** for untraceable on-chain settlement.

3. RAM-Only Diskless Servers:

- Servers run on ephemeral operating system images in memory with no hard drive logging.

4. Real-World Stress Test (2023 Police Raid):

- In April 2023, the Swedish National Police visited Mullvad's Gothenburg offices with a search warrant to seize user data.
- Because of Mullvad's system architecture, no user data or logs existed to seize, and the authorities left empty-handed.

5. No Port Forwarding:

- Mullvad eliminated port forwarding to prevent users from being uniquely fingerprinted or abuse actors from compromising the network integrity.

■ 4. Advanced Tracking Beyond the VPN: Browser Fingerprinting

Using Mullvad or any VPN **only conceals your IP address**. Advanced adversaries and tracking networks do not rely on IPs alone.

4.1 What a VPN CANNOT Protect You From:

- **Browser Fingerprinting:** Websites probe your browser engine using Canvas rendering, WebGL attributes, installed fonts, audio context hardware hashing, and screen geometry. This creates a hash unique to your exact device that persists across IP changes.
- **Persistent State & Cookies:** LocalStorage, IndexedDB, Session Cookies, and Service Workers keep you authenticated and tracked regardless of what VPN node you switch to.
- **Application-Level Telemetry:** Logging into personal accounts (Google, Discord, Steam, Twitter) while connected to a VPN immediately ties that VPN exit IP to your permanent identity.

4.2 The Layered OPSEC Defense Stack

LAYER 5	Human Discipline & Zero Cross-Contamination	Never link personal accounts, phone numbers, or credit cards to burner sessions.
LAYER 4	Ephemeral Operating Systems	Tails OS / Qubes OS / Whonix inside isolated hardware hypervisors.
LAYER 3	Anti-Fingerprinting Browser Engine	Mullvad Browser / Tor Browser (Canvas & WebGL spoofing + uniform user-agents).
LAYER 2	Protocol & DNS Hardening	Encrypted DNS (DoH/DoT), WebRTC disabled, IPv6 dual-stack disabled.
LAYER 1	Network Proxy Layer	Mullvad WireGuard / Multi-hop Tor routing.

- **Golden Rule:** Anonymity is not a software you download; it is an unbroken chain of operational discipline.